Meridian Health Group — Enterprise Technology Context

Platform Overview

HealthConnect is a cloud-native platform built entirely on AWS, designed as HIPAA-eligible from day one. It is a **presentation and workflow layer** — no clinical data is stored permanently in HealthConnect; Epic EHR via FHIR R4 is the source of record. All services are serverless (AWS Lambda) to minimize operational overhead and simplify HIPAA compliance boundary.

Shared Infrastructure

Cloud & Deployment

- **Cloud provider**: AWS — us-east-1 (primary for US patients); eu-west-1 (EU patient data, GDPR residency)
- **Runtime**: Node.js 20 LTS on AWS Lambda (arm64 Graviton); all services deployed as container images via ECR
- **IaC**: AWS CDK v2 TypeScript — all resources version-controlled; no manual console changes
- **CI/CD**: GitHub Actions — lint → unit test → integration → deploy staging → manual production approval
- **Secrets**: AWS Secrets Manager; no secrets in environment variables or code; Epic OAuth credentials, Twilio/SendGrid API keys rotated quarterly

API Gateway & Security

- **API Gateway**: AWS API Gateway (HTTP API) — routes to Lambda services; JWT validation at gateway layer
- **Auth**: AWS Cognito User Pools; PKCE OAuth 2.0 for mobile; session-based for web
- **MFA**: mandatory for all patient accounts — SMS OTP or TOTP authenticator app
- **WAF**: AWS WAF OWASP Top 10 rules at API Gateway
- **PHI tokenization**: Patient identifiers stored as MRN tokens within HealthConnect; plain MRN used only at the FHIR Adapter boundary

Audit Service (HIPAA §164.312)

- Every PHI read and write event emitted to the **Audit Service** via EventBridge
- Immutable append-only log: DynamoDB Streams → S3 Glacier archive; retained **7 years**
- Audit record includes: `patientId` (tokenized MRN), `userId`, action, resource type, timestamp, source IP
- Read-only audit access for Compliance Officers via an internal portal (separate from HealthConnect)

Domain Event Bus

- **AWS EventBridge** is the enterprise event bus for all HealthConnect domain events
- **SQS FIFO** for notification dispatch (at-least-once delivery, deduplication by event ID)
- Key events:

Event	Producer	Key Consumers
`appointment.booked`	Appointment Service	Notification Service, Epic FHIR write-back

`appointment.cancelled`	Appointment Service	Notification Service, FHIR Adapter, Care Coordination
`lab.result.ready`	FHIR Adapter (Epic poll)	Notification Service, Patient Experience frontend
`message.received`	Messaging Service	Notification Service, Care Coordination (inbox badge)
`prescription.requested`	Prescription Service	FHIR Adapter (write-back to Epic GP inbox)
`referral.created`	Care Coordination	Appointment Service, FHIR Adapter

Data Layer

- **Amazon RDS PostgreSQL 15** (Multi-AZ): transactional data (appointment slots, messaging thread metadata, user preferences)
- **Amazon DynamoDB**: audit events, session state, telehealth room state
- **Amazon ElastiCache Redis 7**: FHIR response cache (appointment slots: 60-second TTL; lab results: 15-minute TTL)
- **Amazon S3** (SSE-KMS): message attachments, radiology PDFs, record download exports; pre-signed URLs (5-minute TTL) for secure access

---

Shared Services (Platform Team)

Service	Responsibility
FHIR Adapter	Bi-directional FHIR R4 bridge to Epic; polls lab results every 15 min, radiology every 30 min; write-back for appointments, messages, prescriptions
Auth Service	Patient registration, login, MFA, proxy access grant management (Cognito + Lambda)
Notification Service	SMS (Twilio), email (SendGrid), push (FCM/APNs); patient preference flags respected; SQS FIFO dispatch
Audit Service	PHI access log; EventBridge consumer; DynamoDB + S3 Glacier
File Store	Encrypted attachment management; pre-signed URL generation; S3 SSE-KMS

Engineering Standards

- **Language**: TypeScript (Node.js 20) for all services and frontends
- **API style**: REST (public-facing); GraphQL subscriptions for real-time inbox badge (clinician portal)
- **Framework**: React 18 (frontend); Zod for runtime schema validation on all FHIR payloads
- **Testing**: unit ≥ 80%, integration ≥ 60%; E2E smoke tests on every deploy
- **HIPAA BAA**: signed with AWS, Twilio, SendGrid, Doxy.me, Stripe
- **Pen testing**: annual third-party penetration test; quarterly DAST scan (OWASP ZAP in CI)
- **Encryption**: AES-256 SSE-KMS at rest (all S3 buckets and RDS snapshots); TLS 1.3 in transit
- **Availability**: 99.9% uptime SLA; RTO 4 hours, RPO 1 hour (RDS Multi-AZ + hourly automated backups)